온라인 개인정보 수집

실무 리스크와 대응 사례

SESSION SCOPE

온라인 설문 · 이벤트 등 실무 현장의 개인정보 수집 리스크 사례
위반 의심 사례 대응 및 실무 체크포인트



장보윤 변호사

개인정보보호진흥원 고문변호사
법무법인 제승 대표변호사

2026. 9. 30.(수) · 주최 개인정보보호진흥원 (한국컨설팅산업재단)

처분까지 간 유출 사고의 원인 1위는 해킹이 아니라 업무 실수입니다

2025년 개인정보위가 조사·처분한 유출 사고 115건 기준

CARD 01

유출 처분 115건의 원인

업무 과실 — 46% · 53건

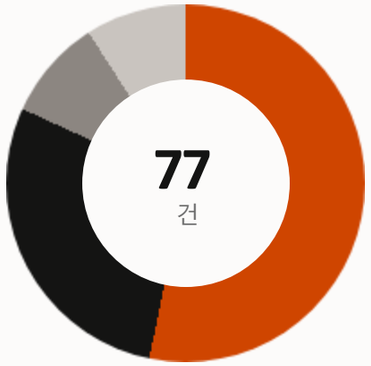
해킹 — 45% · 52건

시스템 오류 — 7% · 8건

신고 단계에서는 **해킹이 62%**로 가장 많지만, 실제 처분까지 간 사건에서는 **업무 실수가 1위**입니다. 해킹은 당한 일이고 업무 실수는 기관이 하지 않은 일이라, 책임을 묻기 쉽기 때문입니다.

CARD 02

공공 부문 처분 77건의 기관 유형



공공기관 41

중앙행정·헌법기관 22

지자체 7

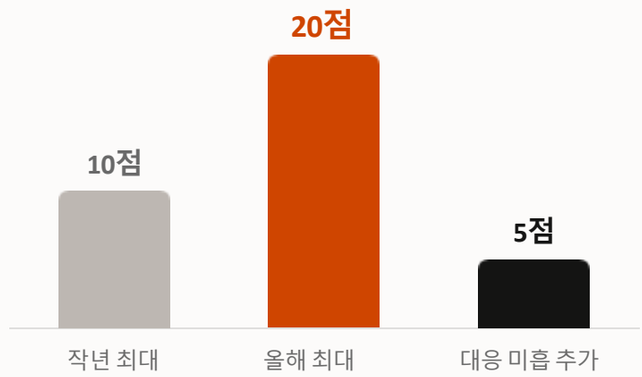
학교 7

전체 처분 227건 · 과징금 1,677억원 · 과태료 5.87억원

전년 대비 172% 증가

CARD 03

2026 공공기관 보호수준 평가 감점



2026.09.11 시행

반복·중대 유출은 매출액의 **10%까지 과징금**. 유출 확정 전 '가능성' 단계 통지 의무 신설 (제34조 제2항). 올해 평가 주제는 '내부자 보안'

출처 · 개인정보보호위원회·KISA 「2025년 개인정보 유출 신고 동향 및 조사·처분 사례」 (2026.5.15) · 개인정보보호위원회 「2026년 공공기관 개인정보 보호수준 평가 추진계획」 (2026.4.13)

공공기관 설문 대부분이 이름과 연락처를 받지만, 동의 문항을 둔 곳은 16%뿐입니다

최근 1년 공공기관 자체 설문조사 실태 (국회토론회 조사, 2026.4)

공공기관이 온라인으로 받는 6가지 유형

설문 · 만족도조사
이름 · 연락처 · 소속 · 응답 내용

행사 · 교육 참가신청
이름 · 연락처 · 소속 · 직급 · (식사 · 알레르기)

경품 · SNS 이벤트 응모
이름 · 연락처 · 주소 · SNS 계정 · (주민번호)

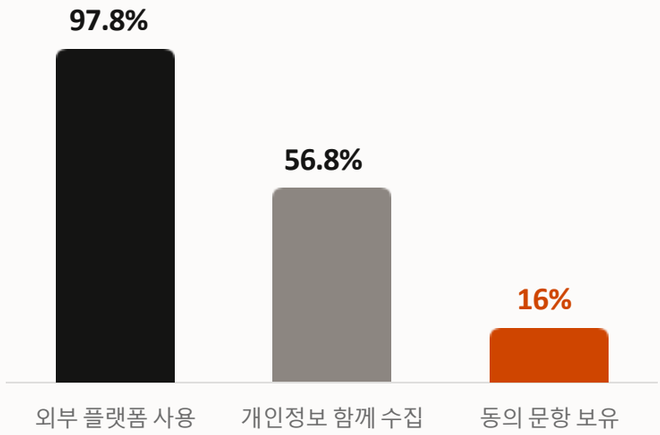
공모 · 모집 · 지원 접수
이름 · 생년월일 · 주소 · 학력 · 경력 · 첨부파일

뉴스레터 · 회원 가입
이름 · 이메일 · 연락처 · 관심 분야

외주 조사 (수탁사가 만든 폼)
어떤 항목을 어디에 저장하는지 기관이 모르는 경우가 많음

SURVEY DATA

자체 설문조사를 한 공공기관 중 (%)



열 곳 중 여덟 곳은 동의 절차 없이 개인정보를 받고 있습니다. 개인정보위는 올해 4월 공공기관에 외부 설문 플랫폼 이용 시 유의사항을 공문으로 보냈습니다.

출처 · 「공공기관 개인정보 온라인 수집 실태 및 대안 마련을 위한 토론회」 자료집 (2026.4.29, 국회의원회관) · 정책브리핑 「개보위 온라인 설문 시 개인정보 보호」 (2026.4.10)

온라인으로 개인정보를 받는 순간 여덟 개 조문이 동시에 적용됩니다

오늘 볼 일곱 가지 사례는 모두 이 조문들에 해당합니다

수집 전에

ARTICLE
제15조

이 정보를 왜 받습니까?

(동의 · 법령 · 소관업무 등 처리 근거)

ARTICLE
제16조

정말 필요한 정보입니까?

(최소 수집 · 입증 책임은 처리자)

보관하는 동안

ARTICLE
제29조

안전하게 관리하고 있습니까?

(접근 권한 · 접속 기록 · 암호화)

ARTICLE
제21조

언제 없앱니까?

(목적이 끝나면 지체 없이 파기)

특별 보호 정보

ARTICLE
제23조

민감정보입니까?

(건강 · 질병 · 별도 동의 · 강화 보호)

ARTICLE
제24조의2

주민등록번호입니까?

(법령상 근거가 있을 때만)

위탁 · 이전 시

ARTICLE
제26조

외부 업체에 맡겼습니까?

(계약 · 감독 · 재위탁 동의)

ARTICLE
제28조의8

해외로 나갑니까?

(고지와 별도 동의)

출처 · 「개인정보 보호법」 (법률 제21445호, 2026.9.11. 시행) — 조문은 요지이며 최신 원문 확인 필요

이름과 연락처를 한 칸이라도 받으면 개인정보 처리이고, 어떤 도구를 쓰는지까지 확인해야 합니다

개인정보위가 올해 4월 공공기관에 공문으로 알린 내용이 바로 이 지점입니다

CASE A

이름 · 연락처가 없는 설문

성별, 연령대, 지역, 응답 내용만 받는다면 개인을 알아볼 수 없으므로 개인정보가 아닙니다. 다만 소속 · 직급 · 연령대를 함께 받아 **누구인지 알 수 있으면 개인정보**입니다 (제2조).

CASE B

이름 · 연락처 · 이메일을 한 칸이라도 받는 설문

- 외부 플랫폼으로 설문한 기관의 **절반 이상**이 경품 제공 · 당첨자 안내를 이유로 받는 항목입니다 (개인정보위, 2026.4)
- 받는 순간부터 개인정보 처리입니다. **제15조 · 16조 · 29조 · 21조가 모두 적용**됩니다
- '받아도 되는 항목'이 아니라 **'근거와 보호 조치가 필요한 항목'**입니다

B를 어떤 도구로 받느냐에 따라

확인할 것이 달라집니다

해외 사업자 서비스 (구글폼 등)

응답이 국외 서버에 저장될 수 있습니다. **국외이전(제28조의8) 고지와 별도 동의**를 검토하지 않고 쓰면 문제가 됩니다.

국내 서비스 (네이버폼 등)

국외이전 문제는 없지만 **안전조치(제29조) · 위탁(제26조)** · 접속·다운로드 기록이 남지 않는 문제는 그대로입니다.

공공기관은 추가로

국가 사이버보안 기본지침 제24조의4와 행안부 고시 제11조에 따라, 업무용 민간 클라우드는 **도입 가능 목록에 오른 국정원 검증 서비스**여야 합니다. CSAP는 2027년 7월 국정원 단일 검증으로 통합될 예정이지만 원칙은 같습니다.

출처 · 정책브리핑 (2026.4.10) · 개인정보 보호법 제2조 · 제28조의8 · 국가 사이버보안 기본지침 제24조의4 · 과기정통부·국정원 공공 클라우드 검증 개편 (2026.4.20)

사례 01 · 행사 참가 신청서

행사 진행에 필요 없는 항목은 받을 근거가 없습니다

왼쪽 신청서의 성명 · 휴대전화 · 이메일 세 칸부터 이미 개인정보 처리입니다. 그 위에 생년월일 · 주소 · 직급까지 필수로 받고 있습니다.

ㅇㅇ 행사 참가 신청

성명 *
홍길동

휴대전화 *
010-0000-0000

이메일 *
name@example.com

생년월일 *
YYYY-MM-DD

자택 주소 *
도로명 주소

소속 · 직급 *
기관명 / 직급

신청하기

※ 실무에서 흔히 보이는 신청서를 재구성한 화면입니다

제16조 ① · 대법원 2016도13263 · 질의응답 Q67

문제가 되는 점

- 성명 · 휴대전화 · 이메일도 개인정보입니다. 처리 근거(제15조)와 보호 조치(제29조)가 필요합니다
- 생년월일 · 자택 주소 · 직급은 행사 진행에 필요한 항목입니까?
- 기준은 하나입니다. **이 항목이 없으면 행사를 못 하는가**
- '예전부터 받았다', '있으면 편하다'는 근거가 아닙니다. **입증 책임은 기관에** 있습니다

이렇게 고칩니다

꼭 필요한 항목만 필수로 두고 나머지는 지웁니다. 남기는 항목은 **필수와 선택을 구분**하고, 각 항목이 어떤 목적에 쓰이는지 한 줄로 설명할 수 있어야 합니다. 대법원 2016도13263은 경품 응모권에 성별 · 동거 여부 · 주민등록번호까지 요구한 사건을 최소수집 원칙 위반으로 판단했습니다.

출처 · 개인정보 보호법 제16조 · 대법원 2017.4.7. 선고 2016도13263 (처리 통합 안내서 p.14) · 개인정보 질의응답 모음집 Q67 (2025.12)

사례 02 · 이벤트 응모 동의 문구

공공기관의 조사는 동의가 아니라 소관업무를 근거로 잡아야 합니다

왼쪽은 응모 마지막 단계에 동의 체크박스 한 줄만 있는 화면입니다. 문구를 고치기 전에, 이 조사를 동의로 처리할 일인지부터 봐야 합니다.

∞ 이벤트 응모 — 마지막 단계

☑ 개인정보 수집 및 이용에 동의합니다. !

응모 완료

동의로 처리한다면 이 화면에 빠진 것

- ✕ 수집 · 이용 목적
- ✕ 수집하는 개인정보 항목
- ✕ 보유 · 이용 기간
- ✕ 동의 거부권과 거부 시 불이익

제15조 제2항: 동의를 받을 때는 이 네 가지를 알려야 합니다

제15조 ① 1호(동의) vs 3호(소관업무)

문제가 되는 점

- 동의로 처리한다면, 네 가지 고지가 없는 이 화면은 **요건 미달**입니다 (제15조 제2항)
- 공공기관의 만족도 · 민원 조사는 **소관업무입니다. 동의가 필요 없습니다** (공공기관 운영법 §13, 민원처리법 §26 등)
- 어느 근거로 처리하든 **처리방침에 근거를 적어** 두어야 합니다 (제22조 제3항)

동의로 처리한다면 이렇게 고칩니다

동의 문구 위에 **수집 · 이용 목적 · 수집 항목 · 보유 · 이용 기간 · 거부권과 거부 시 불이익**을 표로 보여줍니다. 필수 · 선택 동의를 나누고, 응모에 꼭 필요한 항목만 필수로 둡니다. 소관업무 근거라면 동의 문구 대신 처리 근거와 목적을 안내하는 문구로 바꿉니다.

출처 · 개인정보 보호법 제15조 · 제22조 제3항 · 공공기관의 운영에 관한 법률 제13조 · 민원 처리에 관한 법률 제26조

사례 03 · 건강 프로그램 참여 신청서

주민등록번호와 건강정보는 단순히 동의를 받았다고 해서 받을 수 있는 정보가 아닙니다

'일단 받아 두자'가 가장 위험한 항목입니다. 유출되면 피해가 큽니다.

○○ 건강 프로그램 참여 신청

성명 *	홍길동
연락처 *	010-0000-0000
주민등록번호 *	000000-0000000 !
질병명 · 병력 *	예) 고혈압, 당뇨 !
장애 여부 *	선택 !

신청하기

※ 실무에서 흔히 보이는 신청서를 재구성한 화면입니다

주민등록번호 — 제24조의2 · 대법원 2016도13263

'본인이 동의했으니까'라는 이유로는 받을 수 없습니다. **법령에서 구체적으로 요구하거나 허용하는 경우**처럼 법이 인정하는 근거가 있어야 합니다. 신청서에 주민등록번호 칸이 있다면 먼저 확인하십시오. 받을 수 있는 법적 근거가 무엇인지. **답을 못 하면 받지 않아야 합니다.**

건강 · 질병 · 장애 정보 — 제23조 민감정보

일반 개인정보와 같이 다룰 수 없습니다. **별도의 처리 요건과 강화된 보호 조치**가 필요하고, 유출되면 피해가 큽니다. 필요 없으면 지우고, 정말 필요하면 근거와 보호 조치를 갖춘 뒤에 받으십시오.

"고객이 동의했으니까 괜찮겠지" — **주민등록번호에서는 절대 통하지 않습니다**

출처 · 개인정보 보호법 제23조 · 제24조의2 · 대법원 2016도13263 · 공인중개사 개인정보 처리방침 표준(안) 작성지침 (개인정보위 2026.2) p.11

사례 04 · 설문 결과 공개 설정

설문 도구의 결과 공개 설정 하나가 응답자 전원의 정보를 노출시킵니다.

왼쪽 위는 설문 도구의 설정 화면, 아래는 그 설정을 켰을 때 누구나 볼 수 있게 되는 응답 목록입니다. 2022년 12월 실제 제재 사건과 같은 구조입니다.

응답 › 설정

응답 요약 링크 공개
응답자에게 전체 응답 요약을 보여줍니다

ON

모든 응답 (96건) · 링크만 있으면 누구나 열람

성명	휴대전화	이메일
김ㅇ ㅇ	010-****-1234	kim***@***.com
이ㅇ ㅇ	010-****-5678	lee***@***.com
박ㅇ ㅇ	010-****-9012	park***@***.com

실제 제재 사례 — 개인정보위 2022.12.14 전체회의

한 사업자는 구글 설문지의 '결과 요약 보기'를 전체 공개로 설정해 96명·35명의 정보가, 다른 사업자는 네이버폼의 '결과 보기'를 공개로 설정해 67명의 정보가 노출됐습니다. 두 곳 모두 **안전조치 의무 위반으로 과태료**를 받았습니다.

제29조 · 유출등 대응 안내서(2026.9) 사례 1 · 2

결과가 공개돼 있었다면 유출입니까? 두 경우로 나뉩니다

공개됐지만 아무도 열지 않았다

제3자가 접근할 수 있는 상태에 놓여 있었더라도, 실제로 열람 · 접근한 사실이 없었음이 확인된 경우

유출 아님
대법원 2014.5.16. 2011다24555

한 번이라도 열렸다

공개된 동안 다운로드가 한 번이라도 있었던 경우. 즉시 비공개 · IP 특정 불가여도 유출

유출입니다. 72시간 안에 통지 · 신고
대응안내서(2026.9) 사례 2

유출의 기준

개인정보가 법령이나 처리자의 자유로운 의사에 의하지 않고 **관리 · 통제권을 벗어나 제3자가 그 내용을 알 수 있는 상태**에 이른 것입니다 (표준 개인정보 보호지침 §25). 접근할 수 있는 상태만으로는 부족하고, 실제로 열렸는지가 기준입니다. 열렸는지 확인하려면 접속 기록이 있어야 합니다. 기록 이야기는 사례 6에서 이어집니다.

출처 · 개인정보보호위원회 제20회 전체회의 (2022.12.14) 보도자료 · 개인정보 유출등 대응 안내서 (2026.9) p.17~18 · 대법원 2014.5.16. 2011다24555 · 표준 개인정보 보호지침 제25조

사례 05 · 당첨자 발표 게시물

당첨자 발표도 개인정보 처리입니다. 공개할 때도 필요한 만큼만 공개해야 합니다

받을 때는 조심하고 내보낼 때는 잊기 쉬운 경우입니다. 발표를 하지 않아도 응대 과정에서 새는 경우가 있습니다.

공지사항 › ○○ 이벤트 당첨자 발표

○○ 이벤트에 참여해 주신 분들께 감사드립니다. 당첨자는 아래와 같습니다.

등급	성명	휴대전화	거주지
1등	김*수	010-****-1234	서울 강남구
2등	이*영	010-****-5678	경기 성남시
2등	박*민	010-****-9012	부산 해운대구
3등	최*희	010-****-3456	대전 유성구

게시일 2026. 3. 4. · **현재까지 게시 중**

발표하지 않아도 샙니다 — 분쟁조정 사례 Ⅱ-9 (2025)

경품 이벤트 응모자의 이름과 연락처를, 직원이 당첨 문의에 답하다가 다른 응모자에게 화면 캡처로 보냈습니다. 목적 밖 제3자 제공으로 **손해배상 20만원과 직원 교육**이 결정됐습니다.

제15조① · 제16조 · 제21조 · 제34조의2 · 대법원 2016도13263

문제가 되는 점

- 응모할 때 받은 동의에 '당첨자 공개' 목적과 공개 항목이 들어 있었습니까? 없으면 **목적 밖 이용**입니다
- 이름 일부, 전화번호 일부, 거주지를 함께 보면 **누구인지 알 수 있습니다.** 공개할 때도 필요한 만큼만입니다
- 이 게시글은 언제 내립니까? 목적이 끝났는데 남아 있는 공개 정보입니다

이렇게 고칩니다

당첨 통보는 개별 연락으로 합니다. 공개가 꼭 필요하면 응모 단계에서 공개 목적 · 항목 · 기간을 알리고, 공개 항목은 누구인지 알기 어려운 최소한으로 줄이고, 게시 종료일을 정해 내립니다.

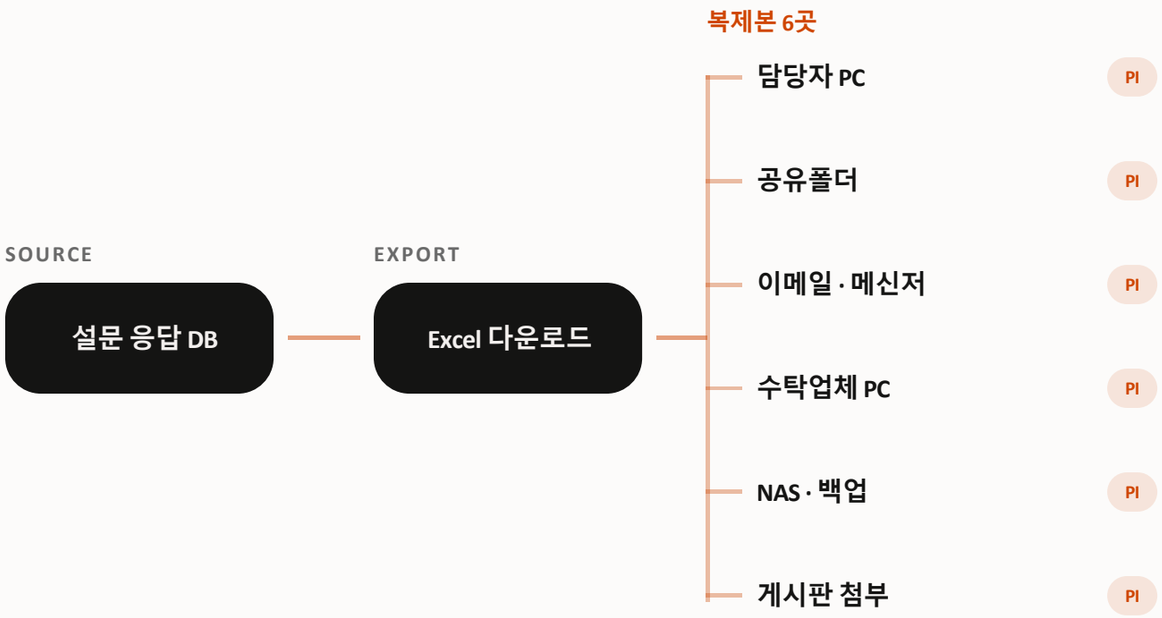
제34조의2: 게시한 뒤에는 개인정보가 공중에 노출되지 않도록 할 의무가 있고, 개인정보위나 전문기관이 요청하면 삭제 · 차단해야 합니다.

출처 · 2025년 개인정보 분쟁조정 사례집 Ⅱ-9 (p.86~88) · 개인정보 보호법 제15조 · 제16조 · 제21조 · 제34조의2 · 대법원 2016도13263

사례 06 · 설문 종료 후

설문 폼을 지워도 개인정보는 남습니다.
복제본은 여섯 곳에 있고, 기록이 없으면 파기를 입증할 수 없습니다

이달 9일 의결된 사건에서, 서버 로그를 남기지 않은 사업자는 피해 규모를 확인하지 못했고 로그 미보관 자체가 처분 사유가 됐습니다.



'폼은 삭제했습니다'라고 해도 복제본은 남습니다

※ 데이터 복제 구조를 도식화한 화면입니다

제21조 · 제29조 · 안전성 확보조치 §8

문제가 되는 점

- **설문 폼 삭제와 개인정보 파기는 다른 일**입니다 (제21조)
- 접속 기록 1년, 5만 명 이상 · 민감정보는 2년 보관, 다운로드 내역을 점검해야 합니다 (안전성 확보조치 §8)
- 로그 미보관 사업자는 피해 규모 확인 불가, **로그 미보관 자체가 처분 사유**였습니다 (의결서 2026-217-391호)

설문이 끝나면 여섯 곳을 확인합니다

① 플랫폼 응답 DB ② 내려받은 파일 ③ 공유폴더
④ 담당자 PC · 메일함 ⑤ 수탁업체 보유본 ⑥ 백업

근거 없는 것은 파기하고, 보관할 것은 기록이 남는 시스템으로 옮깁니다. **파기 일시 · 방법을 기록**해 두어야 나중에 파기 사실을 입증할 수 있습니다. 이런 보호 환경 투자는 과징금 감경 사유입니다 (시행령 §60의2).

출처 · 개인정보 보호법 제21조 · 제29조 · 안전성 확보조치 기준 제8조 · 심의의결서 제2026-217-391호 (2026.9.9) · 시행령 제60조의2

사례 07 · 외주 조사 (처리 위탁)

조사를 외주로 맡겨도 관리 책임은 기관에 남고, 감독 의무가 하나 더 생깁니다

‘업체가 알아서 했다’로 끝나지 않는 구조입니다. 위탁 법리는 앞 세션에서 다뤘으므로 여기서는 확인할 것만 봅니다.

○○공공기관 고객만족도 조사 위탁 구조

1. 공공기관이 고객만족도 조사를 발주
2. 조사업체(수탁사) 선정 · 계약
3. 조사업체가 자기 시스템으로 개인정보를 직접 수집 !
4. 결과 분석 · 보고서 작성
5. 공공기관은 보고서만 받고 종료 !

※ 실무에서 흔히 보이는 위탁 구조를 재구성한 화면입니다

제26조 ①②④⑥ · 시행령 §28

문제가 되는 점

- **외주를 줘도 개인정보 관리 책임은 넘어가지 않습니다**
- 업체가 어떤 정보를, 어떤 시스템에서, 누가 처리하는지 기관이 확인해야 합니다
- 공공기관이면 수탁사의 조사 시스템도 **도입 가능 목록과 국정원 검증 대상**입니다
- 기관이 직접 하든 업체가 하든 위반 항목은 줄지 않고, 위탁이면 **감독 의무 위반이 하나 더** 붙습니다 (§26 ④)

이렇게 고칩니다

계약서와 과업지시서에 **조사 시스템, 저장 · 파기 방법, 재위탁 조건**을 적어 두고, 필요한 범위에서 실제 처리 현황을 점검합니다.

출처 · 개인정보 보호법 제26조 · 시행령 제28조 · 국가 사이버보안 기본지침 제24조의4 (수탁사 시스템 적용)

05 · 실무 체크리스트

설문을 만들 때 네 가지 확인사항

일곱 사례를 단계별 확인 항목으로 정리했습니다. 배포자료로도 드립니다.

01 · 만들 때

- 처리 근거부터 정합니다 (소관업무인지 동의인지)
- 항목마다 왜 필요한지 한 줄로 적을 수 있는지 (입증 책임은 기관)
- 동의라면 목적 · 항목 · 기간 · 거부권을 알립니다
- 주민등록번호 · 건강 · 장애 입력란이 없는지

02 · 배포 전

- 결과 공개 · 요약 보기 옵션이 꺼져 있는지
- 기관 계정 · 기록이 남는 시스템인지 (개인 계정 무료 폼은 안 됨)
- 해외 서비스면 국외이전 고지 · 동의, 공공기관은 도입 가능 목록 확인
- 처리방침과 개인정보파일 현황에 반영하고 결재를 받았는지

03 · 운영 중

- 응답 다운로드 권한을 최소 인원으로
- 내려받은 파일이 어디로 가는지 통제
- 응답자가 문의 · 삭제 요청할 창구
- 당첨자 등을 공개할 때 항목과 기간을 최소로

04 · 종료 시

- 필요한 데이터는 내부 시스템으로 옮깁니다
- 외부 플랫폼과 개인 계정의 데이터를 삭제합니다
- 복제본 여섯 곳을 확인합니다
- 파기 일시와 방법을 기록합니다

출처 · 개인정보 보호법 제15 · 16 · 21 · 29 · 30 · 32조 · 처리 통합 안내서 · 2026 처리방침 작성지침 · 국가 사이버보안 기본지침 제24조의4

문제 발견시 대응방법

자체 점검, 정보주체 문의, 외부 진단 통보, 감사 지적. 경로는 달라도 그 다음 여섯 단계는 같습니다.

ROUTE 01

자체 점검에서 발견

가장 다행인 경우

먼저 할 일

1. 설정을 바꾸기 전에 지금 화면을 캡처합니다
2. 설정을 바꾸고 응답 접수를 중단합니다
3. 부서장과 개인정보 담당자에게 보고합니다

ROUTE 02

정보주체 문의 · 민원

“제 정보가 왜 보이죠?”

먼저 할 일

1. 답하기 전에 사실부터 확인합니다
2. 확인 전에 ‘문제없습니다’라고 답하지 않습니다
3. 접수 일시와 내용을 기록합니다

ROUTE 03

외부 진단 · 통보 수신

진단 도구 · 시민단체 · 언론

먼저 할 일

1. 통보받은 내용을 그대로 보관합니다
2. 어느 링크, 누구 담당인지 특정합니다
3. 기관 차원의 대응 창구를 정합니다

ROUTE 04

감사 · 상급기관 지적

보호수준 평가 · 정기 점검

먼저 할 일

1. 지금까지 조치한 이력을 문서로 준비합니다
2. 담당 부서를 넘어 개인정보 보호책임자에게 보고합니다
3. 재발 방지 계획을 붙입니다

경로가 달라도 **그 다음 여섯 단계는 같습니다**

출처 · 2025년 개인정보 분쟁조정 사례집 (정보주체 문의 경로) · 2026년 공공기관 보호수준 평가 추진계획 (감사 경로)

여섯 단계 중 첫째는 응답 접수를 중단하는 것입니다. 확인하는 동안에도 설문 링크는 열려 있습니다

1단계를 먼저 하고 2단계를 합니다. 유출 여부는 세 가지 질문으로 판단합니다.

1 접수 중단

설문 링크를 비활성화하거나 응답 접수를 막습니다.
결과가 공개 설정이면 **즉시 해제**합니다

2 사실 확인

현재 설정, 수집 항목, 동의 문구를 **화면 캡처로 남깁니다**.
누구 계정인지, 언제부터, 몇 명이 응답했는지 파악합니다

3 유출 여부 판단

누군가 열었는가, 열었다면 몇 번 · 누가, 모른다면 왜 모르는가. **한 번이라도 열렸으면 유출이고 72시간 안에 통지 · 신고.** '가능성 통지'는 불법 접근 정황이 있을 때 적용 (시행령 §39의2)

4 데이터 정리

필요한 것은 내부 시스템으로 이관,
외부 플랫폼 · 개인 계정 · 복제본은 삭제합니다 (제21조)

5 기록

조치 일시 · 내용 · 담당자를 문서로 남깁니다.
감사 · 점검에서 '무엇을 했는가'의 증거가 됩니다

6 재발 방지

외부 폼 사용 승인 절차를 만들고,
처리방침 · 개인정보파일 현황에 반영합니다 (§30 · §32)

출처 · 개인정보 보호법 제21 · 30 · 32 · 34조 · 시행령 제39조의2 · 개인정보 유출등 대응 안내서 (2026.9)

잘못된 대응 다섯 가지

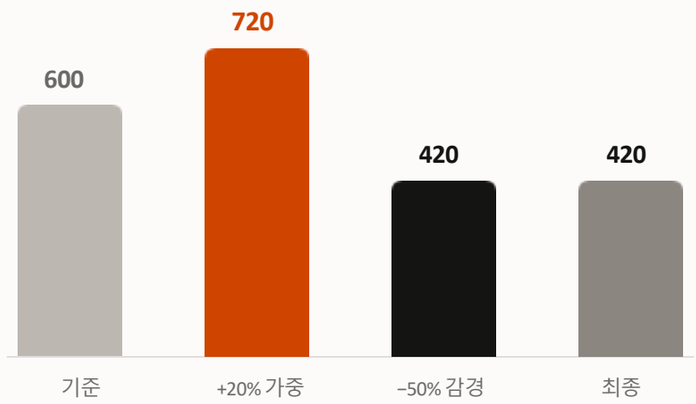
대응 과정에서 오히려 문제를 키우는 다섯 가지와, 이달 의결서에 나온 과태료 산출 구조

링크만 지우고 끝내기	폼을 지워도 내려받은 파일, 개인 계정, 복제본은 그대로입니다. 확인 전에 지우면 **증거 인멸로 볼 수 있습니다.**
담당자 혼자 처리하기	부서장, 개인정보 담당, 보호책임자에게 보고되지 않은 조치는 **기관의 조치가 아닙니다.** 감사에서 '기관은 몰랐다'가 더 큰 문제가 됩니다.
확인 전에 '문제없습니다'라고 답하기	정보주체에게 성급하게 답한 내용은 그대로 남습니다. **확인한 뒤 답하고, 확인 중이면 '확인 중'이라고 답합니다.**
캡처 없이 설정부터 바꾸기	고친 뒤에는 무엇이 어떻게 잘못돼 있었는지 증명할 방법이 없습니다. **바꾸기 전 화면이 유일한 기록입니다.**
개인 계정의 폼을 담당자가 지우기	담당자가 자기 계정에서 지우면 기관은 파기를 확인할 수 없습니다. **기관 계정으로 옮기거나, 파기 과정에 입회해 기록합니다.**

CASE STUDY

과태료 산출 (만원)

심의의결서 2026-217-391호



사전통지 전에 시정을 마치고 조사에 협력해 **과태료가 절반으로 감경**됐습니다. 반대로 위반 상태가 6개월 넘게 이어지면 처분 결과가 1년간 공표됩니다.

출처 · 개인정보보호위원회 심의의결서 제2026-217-391호 (2026.9.9) 과태료 산출내역 · 개인정보 보호법 위반에 대한 공표 및 공표명령 지침 제2조

오늘 가져가실 세 가지

01 이름을 한 칸이라도 받으면 개인정보 처리입니다. 어떤 도구를 쓰는지까지 확인하십시오

해외 서비스는 국외이전, 공공기관은 도입 가능 목록. **'이름 · 연락처 정도'라는 예외는 없습니다**

02 처분까지 가는 원인 1위는 해킹이 아니라 업무 실수입니다

유출 처분 115건 중 **46%**. 설문을 만들 때 체크리스트만 확인해도 막을 수 있습니다

03 문제를 알게 되면 캡처하고, 접수를 중단하고, 보고하십시오. 지우지 마십시오

확인 전 삭제는 증거 인멸로 읽히고, **조사 협력과 사전 시정은 과태료를 절반으로** 줄입니다

배포하기 전에 점검하면 문제를 방지할 수 있습니다.

개인정보보호진흥원(한국컨설팅산업재단) 연중 운영 · 무료 · 회원가입 없음

SELF · DIAGNOSIS TOOL

SURE-CHECK

sure-check.org

- 설문 링크를 넣거나 설문 파일을 올리면 **개인정보 수집 관련 위험 신호를 점검**합니다
- 설문을 만드는 담당자도, 링크를 받은 응답자도 쓸 수 있습니다
- 오늘 본 '만들 때'와 '배포 전' 항목 중 화면으로 확인할 수 있는 것을 미리 점검합니다
- 개인정보위가 **2,300여 공공부문**에 요구하는 자체 점검을 실행하는 도구입니다



※ 진단 결과 예시 화면 · 진단 대상 URL · 기관명은 가린 상태입니다

WORKFLOW

먼저 점검하고, 문제가 있으면 항목과 동의 문구를 고친 뒤에 **배포하십시오**

출처 · 개인정보보호진흥원 · 개인정보위 2026년 하반기 업무계획 (공공부문 자체 점검 관리 · 지원)

Q&A

질문을 받겠습니다

장보윤 변호사
개인정보보호진흥원 고문변호사 · 법무법인 제승 대표변호사